ECDAT (SIH 2026 PS 26164): Competitive Landscape, Cutting Edge & How to Win

TL;DR

Your architecture is technically sound but sits in a crowded, fast-maturing field (IBM CBOMkit/Quantum Safe Explorer, SandboxAQ AQtive Guard, PQShield, Keyfactor, Encryption Consulting) — judges scoring Innovativeness/Creativity will benchmark you against these, so your differentiation must come from what those tools *measurably fail at*: cross-tool correlation, CBOM trust/provenance, India-sovereign compliance mapping, and reachability-based prioritization — **not** from "we scan for RSA."

The three highest-ROI, lowest-cost differentiators for an NTRO audience are: (1) a **multi-scanner ensemble that de-duplicates and reconciles conflicting findings** (directly attacks the documented #1 weakness of every existing CBOM tool); (2) **India-sovereign compliance mapping** (DST/NQM 2027–2029 CII deadlines, RBI Q-SAFE CBOM mandate, CERT-In/CISA-style product categories, CNSA 2.0) baked into the risk engine; and (3) a **cryptographically signed, tamper-evident CBOM** (CycloneDX JSF/JWS signing) — a government-grade trust feature no student team will show.

Do **not** attempt full unknown-crypto detection; instead add a cheap, clearly-labelled "candidate custom-crypto" heuristic (entropy + XOR/loop/S-box constant patterns) plus a YARA binary-constant scanner. Together they recover most of the judge-visible novelty of your descoped feature for ~1 day of effort, and echo NTRO's own SIH-2025 firmware-crypto interest.

Key Findings

1. The competitive landscape judges will benchmark you against

The problem statement's phrase "existing solutions" maps to a real 2026 market. The tools you will implicitly be compared to:

IBM Quantum Safe Explorer / Advisor / Remediator + CBOMkit (now under the PQCA / Linux Foundation). Explorer does static source+object-code scanning to build a CycloneDX CBOM; Advisor adds runtime/network correlation and policy compliance; Remediator deploys quantum-safe patterns. The open-source **CBOMkit** — Hyperion (a SonarQube-based source scanner supporting Java, Python, Go, with experimental C/C++ via sonar-cxx and C# via ANTLR; Go added in 2026), Theia (container/directory/certificate/key scanner), Coeus (CBOM viewer), plus a Compliance Engine — is the **direct open-source competitor to your Tier-1 MVP**, and it is free. Judges may literally ask "why not just use CBOMkit?" You need a crisp answer (see Details).

SandboxAQ AQtive Guard — the enterprise leader. Per SandboxAQ's Dec 10, 2025 press release (PR Newswire), it signed a five-year agreement in which "the DoW CIO is now leveraging the company's AQtive Guard platform for comprehensive, automated cryptographic discovery and inventory (ACDI)"; AQtive Guard also reached FedRAMP Ready status in December 2025. Its distinguishing edge: it discovers crypto from

runtime/network behavior (passive TLS/SSH/IPsec inspection, ML-based), catching shadow keys and dynamically loaded libraries that static file scanners miss. Cybercompanyprofiles ↗
This is the axis where a static-only tool looks weak — acknowledge it proactively.
PQShield, Keyfactor (AgileSec / Command), Fortanix DSM, InfoSec Global AgileSec, Crypto4A QxEDGE, Encryption Consulting CBOM Secure, QCecuring — a spread from certificate-lifecycle-management-plus-CBOM to compliance-focused platforms.
Cloudflare / Google — not inventory tools; they are PQC *deployment* players and are best used as "the migration destination" context. Cloudflare states (April 2026 blog): "We are targeting full post-quantum security including authentication for our entire product suite by 2029," via a phased roadmap (mid-2026 ML-DSA origin authentication; mid-2027 Merkle Tree Certificates; early 2028 Cloudflare One SASE; 2029 completion). Its hybrid ML-KEM adoption is real and large: "As of March 2025, well over a third of the human web traffic reaching the Cloudflare network is protected against these attacks by TLS 1.3 with hybrid ML-KEM key exchange," and per Cloudflare Radar's 2025 Year in Review, "the share of human-generated Web traffic that is post-quantum encrypted has grown to 52%" by end of 2025.

The documented weakness you should exploit. A 2026 ARES workshop paper — "An Empirical Analysis of Open-Source Tools for Cryptographic Asset Discovery for PQC Readiness Assessment" (Olewinski, Ebinger & Sandler; LNCS vol. 16902, pp. 342–360; DOI 10.1007/978-3-032-35586-7_19) — benchmarked open-source CADI tools against a defined ground truth and found "a fragmented open-source landscape, with significant gaps," "deficits in detection completeness and accuracy," and that "the permissiveness of the current [CBOM] specification hinders interoperability and aggregation." Its top recommendation: **"orchestrating heterogeneous CADI tools" and "imposing stricter CBOM conformance requirements."** ACM Digital Library ↗
A companion ICPC 2026 tool paper, **BF-CBOM** (Bögli, Spieler & Kehrer, University of Bern; DOI 10.1145/3794763.3794831), ran four CBOM generators (CBOMkit, cdxgen, Santander's CryptobomForge, and an LLM) on the same repos and reported: "Reported cryptographic assets were strikingly inconsistent. Tools disagreed on which cryptographic components to include and on how much metadata to provide. Overlaps were rare, with almost no lexically exact matches," concluding this "confirm[s] the immaturity of CBOM tooling — reinforcing the value of investigating code with multiple generators in ensemble to compensate for individual blind spots." **This is your opening: your Correlation Engine already does cross-scanner fusion — reframe it as an ensemble that compensates for individual tools' documented blind spots.**

2. Standards status (through 2026) — get these exactly right on stage

NIST PQC: FIPS 203 (ML-KEM), 204 (ML-DSA), 205 (SLH-DSA) finalized Aug 13, 2024. Per NIST IR 8545 (Fourth Round status report, announced March 11, 2025), **HQC (Hamming Quasi-Cyclic) was selected as the code-based backup KEM to ML-KEM**, with a draft standard planned ~1 year later and finalization expected in 2027. **FN-DSA (Falcon)** draft (FIPS 206) is in progress. AES-256 and SHA-384/512 remain quantum-resistant (Grover only halves symmetric security).
CycloneDX CBOM: v1.6 (April 2024) added native crypto assets and CycloneDX Attestations (CDXA); became **ECMA-424** (July 2024). **v1.7 was released October 21, 2025**, adding an **Algorithm Family object and a machine-readable Cryptography Registry** (algorithm families + elliptic curves, deprecating the v1.6

`curve` property); it "is expected to be ratified as ECMA-424, 2nd Edition" (December 2025). Support ⩾1.6 and reference 1.7 to show currency.

US compliance: CNSA 2.0 (National Security Systems: ML-KEM-1024, ML-DSA-87; Jan 1, 2027 new-acquisition mandate; ~2033/2035 completion targets); NIST IR 8547 (civilian: deprecate RSA/ECC after 2030, disallow after 2035); Encryption Consulting ↗ NIST SP 1800-38 (NCCoE migration practice guide). Note the Gartner prediction widely cited in SandboxAQ coverage (The Quantum Insider, Dec 2025) that "quantum computing will render traditional cryptography unsafe by 2029" — this is a *prediction*, useful for urgency framing but not a fact.

India (this is your NTRO gold):

DST / National Quantum Mission Task Force report, "Implementation of Quantum Safe Ecosystem in India" (Feb 2026; finalized ~May 2026 as "Quantum-Safe Ecosystem in India: Roadmap to Quantum Resiliency"), chaired by **Dr. Rajkumar Upadhyay (CEO, C-DOT)**, co-chaired by **Prof. Manindra Agrawal (Director, IIT Kanpur)**; sub-groups led by **TEC** (testing/certification) and **DSCI** (migration strategy). **CII (defence, power, telecom, transport, BFSI) milestones: foundations by Dec 2027, high-priority migration by Dec 2028, full PQC adoption by Dec 2029.** It recommends **mandatory cryptographic inventories**, crypto-agile design, and PQC requirements in procurement. Critically, India plans a national list of cryptography-dependent product categories modeled on **CISA's Jan 2026 advisory**, with two India-specific additions: **mobile phones AND "automated cryptographic discovery and inventory solutions"** — i.e., a tool exactly like ECDAT is named as a future compliance product category. Cite this on stage; it is the single strongest "real-world alignment" fact you have.

RBI Q-SAFE Committee ("Expert Committee for a Quantum Secure and Adaptive Financial Ecosystem," constituted 25 May 2026; Convener Dr. Anil Prabhakar, IIT Madras): its terms of reference explicitly include "a sector-wide diagnostic audit using a Cryptography Bill of Materials (CBOM)" and evaluating crypto-agility across Indian banking/payments (RBI, NPCI, SBI, DSCI, MeitY, DST members). A national regulator has literally mandated CBOM-based audits.

CERT-In / RBI / SEBI are increasingly pushing SBOM/CBOM transparency for regulated entities (vendor contracts, audits), per Indian security-industry analysis.

DRDO stood up a Quantum Research Centre (Delhi, May 2025) and runs QKD/PQC programs (with Taqbit Labs). NTRO's own **SIH 2025 problem statement was AI/ML crypto-primitive detection in firmware binaries** — a strong signal that NTRO values the binary/firmware angle.

CISA "Product Categories for Technologies That Use Post-Quantum Cryptography Standards" (published Jan 23, 2026, with NSA, under EO 14306): a two-tier "Widely Available" (cloud, collaboration, browsers/web servers, endpoint/full-disk encryption) vs "Transitioning" (networking, SaaS, telecom, ICAM) list; PQC-enabled requires FIPS 203/204/205. India's roadmap explicitly models its own product-category list on this.

3. Static/binary crypto detection — the feasible middle ground for your "descoped" idea

Your instinct to descope full unknown-crypto detection is correct — it is a decades-old hard research problem. But there is a cheap, defensible middle ground:

Known-signature detection (what you have): Semgrep + CBOMkit-style AST rules catch library API calls. Fine, but library-dependent and prone to false positives on test vectors/comments/dead code.

Constant/artifact-based binary detection (cheap, high-signal): Tools like **FindCrypt2, signsrch, findcrypt-yara** identify algorithms by known magic constants (AES S-boxes, SHA/MD5 init vectors, RSA OIDs). You can ship a **YARA-rule-based binary/blob/container-layer scanner** in ~1 day that flags AES/DES/3DES/RSA/SHA constants — this materially extends beyond Syft/Trivy (which do SBOM/CVE, not crypto-constant detection) and directly echoes NTRO's SIH-2025 firmware interest.
The "candidate custom-crypto" heuristic (novelty recovery): Full proprietary-crypto identification (academic "Where's Crypto?", CryptoHunt, CIS — all relying on data-flow graphs and bit-precise symbolic execution) is genuinely out of scope. But a **lightweight heuristic flag** is buildable: high Shannon-entropy regions + tight loops dense in XOR/shift/rotate/modular arithmetic + large constant lookup tables ⇒ "possible custom cryptographic routine — needs manual review." Present it explicitly as a **low-confidence "candidate" signal**, not detection. This recovers most of the judge-visible novelty of the descoped feature at a fraction of the cost, and being honest about its limits scores well with a technical panel.
LLM-assisted enrichment (optional, well-precedented): 2024–2026 research ("Quantum-Safe Code Auditor"; studies showing GPT-4o-mini beating CryptoGuard/CogniCrypt on the CryptoAPI/MASC benchmarks) uses an LLM as a *second-pass classifier* to cut false positives and add severity/context. A single LLM call per finding to classify "real production crypto vs. test vector/comment/dead code" is cheap and directly attacks static analysis's biggest weakness. Frame it as enrichment, never as primary detection.

4. Genuinely differentiating, hackathon-buildable features (ranked by ROI)

A. Multi-scanner ensemble + conflict reconciliation (build on your Correlation Engine) — highest novelty-per-effort. The 2026 literature (ARES, BF-CBOM) shows every existing tool disagrees and misses assets. Make your correlation *visible*: in the GUI, show that Semgrep found X, CBOMkit-style rules found Y, the binary scanner found Z, and your engine **reconciled and deduplicated** them into one authoritative CBOM with a per-asset **"detected-by-N-scanners" confidence score**. This is exactly BF-CBOM's academic thesis, it is buildable, and no student competitor will articulate it.

B. Cryptographically signed, tamper-evident CBOM (government-grade trust). Because CBOMs are CycloneDX documents, they support **enveloped signing via JSON Signature Format (JSF)/JWS** natively — CycloneDX has a top-level `signature` field with an `excludes` mechanism and multi-signature support; there is official `cyclonedx-sign-javascript` tooling; and cdxgen already supports both component-level and BOM-level JWS/RSA signing ("a tamper-evident seal over the complete SBOM"). Add a "Sign CBOM" button that produces a signed, verifiable report, and optionally note **CycloneDX Attestations (CDXA)** and external **in-toto/Sigstore-Cosign+Rekor** attestation. For an NTRO/defence audience, a tamper-proof cryptographic inventory is a compelling sovereignty/audit story that costs ~half a day.

C. India-sovereign compliance mapping (the NTRO clincher). Instead of only CNSA 2.0/NIST, map every asset to **India's DST/NQM 2027–2029 CII deadlines, the RBI Q-SAFE CBOM requirement, and CERT-In/CISA-style product categories**, emitting a COMPLIANT / NON-COMPLIANT / AT-RISK verdict plus the specific deadline each asset misses. Your Tier-2 policy-YAML engine already provides the mechanism — ship it preloaded with an **"India CII policy pack."** This directly wins Social Impact + real-world alignment and proves you researched the sponsor.

D. Mosca-based "quantum risk timeline" with a live threat-horizon slider. Make your Mosca engine the demo centerpiece. Plot each asset on a timeline (X = migration time, Y = data shelf-life, Z = CRQC horizon) and let judges **drag the Q-Day slider** (2029 aggressive ↔ 2035 conservative) to watch assets flip red in real time. Recent academic work (Quantigence; the QARS model) extends Mosca's binary inequality into a **continuous urgency ratio r = (X+Y)/Z mapped through a sigmoid** — implement that for smooth color gradients instead of a binary flip. Interactive + explainable = strong Creativity and Presentation marks.

E. "Blast radius" as a reachability graph. You have Blast Radius + React Flow. Elevate it: fuse internet-facing + sensitive-data-flow flags (your Tier-2 "Crypto Reachability") into a dependency graph where a single vulnerable root CA or shared library **lights up everything it transitively protects**. This visually answers the real migration-prioritization question — "which one fix protects the most?" — that regulators care about.

5. What to prioritize given the rubric

The rubric is dominated by Innovativeness (10) + Creativity (10) + Implementation (10); Social Impact (5) + Presentation (5) are smaller but cheap to win. Your plan is strong on Implementation, but "reuse known scanners in a standard architecture" caps your Innovativeness/Creativity — exactly your stated concern. The three features that move those two 10-point axes most for least effort are **A (ensemble/reconciliation), B (signed CBOM), and C (India compliance pack)** — collectively ~1–2 days of build and all things the incumbents and other teams won't show. **D and E** repurpose components you already have into demo showmanship for Presentation, and **C** doubles as your Social Impact story.

Details

Neutralizing the "you just wrapped open-source scanners" critique. CBOMkit is free and already does source+container CBOM generation, so "we ran Semgrep and produced a CBOM" is not novel to an informed judge. Your defensible position is *the analysis and trust layer on top*: (i) you fuse multiple scanners and reconcile their documented disagreements; (ii) you add quantum-risk scoring, India-compliance verdicts, and signed provenance that pure generation tools lack; (iii) you visualize reachability and the Mosca timeline interactively. Say it plainly: **"CBOM generation is commoditized; the hard, unsolved problems are correlation, trust, and prioritization — that is ECDAT."**

Standards precision matters for a technical panel. Use standardized names (ML-KEM not Kyber, ML-DSA not Dilithium, SLH-DSA not SPHINCS+). Know HQC is a *backup* KEM (2025 selection per NIST IR 8545, ~2027 standard) and SLH-DSA is the conservative hash-based signature (large signatures, slow). Cite CycloneDX 1.6→1.7 and ECMA-424. Getting a name wrong in front of NTRO erodes credibility disproportionately.

On runtime/network discovery (AQtive Guard's edge). Your tool is static (code/binary/container). The honest, strong framing: static discovery is the correct first step for *this* SIH deliverable (the PS explicitly scopes repos, binaries, libraries, container images), and a network/runtime analyzer is the natural Phase-2 extension. Pre-empting "what about runtime crypto?" demonstrates maturity rather than a gap.

On the "candidate custom-crypto" flag — scope it out loud. Label it heuristic/low-confidence, display the signals (entropy, XOR-loop density, lookup tables), and state that full proprietary-crypto identification

remains an open research problem requiring symbolic execution / data-flow-graph analysis that does not generalize. A technical panel rewards knowing exactly where the research frontier is and scoping honestly against a 6-day timeline.

Recommendations

Stage 1 — Lock the differentiation narrative (Day 1, before more coding). Adopt the thesis: *"CBOM generation is commoditized and, per 2026 research, individual tools disagree and miss assets. ECDAT is a correlation, trust, and prioritization layer, tuned to India's sovereign compliance timeline."* Put the ARES/BF-CBOM "tools disagree, overlaps rare" finding on a slide as your problem framing.

Stage 2 — Build the three high-ROI differentiators (Days 2–4).

Ensemble reconciliation + per-asset confidence score in the Correlation Engine and GUI. *Benchmark to hit:* merge ≥3 scanners' outputs and show at least one asset that only a single scanner caught.
Signed CBOM (CycloneDX JSF/JWS) + a verify step. *Benchmark:* produce a signed `cbom.json` and demonstrate tamper-detection live (edit one byte → verification fails).
India CII compliance pack in the policy engine mapping to DST 2027/2028/2029, RBI Q-SAFE, CNSA 2.0, NIST IR 8547. *Benchmark:* every asset receives a verdict tied to a named Indian deadline.

Stage 3 — Convert existing components into demo theatre (Day 5). Interactive Mosca timeline with a draggable Q-Day slider (continuous sigmoid urgency), and a reachability graph where fixing one root asset visibly clears many downstream systems. Rehearse a single 3-minute "harvest-now-decrypt-later on a long-lived Indian CII dataset" narrative end-to-end.

Stage 4 — Cheap novelty add-ons only if time remains. YARA-based binary crypto-constant scanner (extends beyond Syft/Trivy, echoes NTRO firmware interest); LLM second-pass false-positive filter; the low-confidence "candidate custom-crypto" heuristic flag.

Descope discipline / thresholds that change the plan. If ensemble reconciliation slips past Day 3, cut the YARA scanner and LLM filter first — protect A, B, C. If the signing library fights you, downgrade to a SHA-256 hash + detached-signature demo (still proves tamper-evidence). Never sacrifice a working end-to-end demo for a half-built feature: Time Discipline is penalty-based and Implementation rewards a polished, complete prototype over breadth.

Caveats

The ARES 2026 paper's specific numeric completeness/accuracy figures are paywalled; only its qualitative conclusions ("deficits in detection completeness and accuracy," "fragmented landscape") ACM Digital Library ↗ are quoted here. BF-CBOM's "tools disagree / overlaps rare" quotes are from the open preprint and are the more concrete of the two.

Vendor capability claims (AQtive Guard, IBM, Keyfactor, Cloudflare) are largely from vendors' own materials and secondary analyses; treat exact feature claims as marketing-inflected, though the *categories* of capability are well corroborated. Cloudflare's 2029 target and the Gartner "2029" line are explicitly predictions, not established facts.

India's DST roadmap is **advisory**, not yet binding regulation; enforcement depends on sector regulators. The RBI Q-SAFE CBOM mandate is the most concrete Indian anchor. Present the 2027–2029 CII deadlines as roadmap targets, not law.

Q-Day timing is genuinely uncertain (credible estimates span ~2029–2040). Your draggable-horizon design correctly treats this as a tunable variable rather than asserting a date — keep it that way on stage.

US Executive Order references (14144, 14306, and a reported June 2026 PQC EO) appeared across multiple secondary sources but were not verified against primary White House text; cite EO numbers cautiously.